

ĐỀ THI CTF JEOPARDY

- Mã học phần: UET.CN3124
- Tên học phần: An toàn và an ninh mạng
- Tên đề thi: Thi CTF theo mô hình Jeopardy - Tổng hợp các bài toán và câu hỏi về Trí tuệ Nhân tạo
- Chủ đề: CTF / Scripting / Miscellaneous
- Học và tên sinh viên:
- Mã số sinh viên:
- Ngày thi:
- Thời gian thi: 14

LỜI CẢM ƠN

Lời đầu tiên, em xin gửi lời cảm ơn chân thành tới các thầy cô giảng dạy bộ môn UET.CN3124 - An toàn và an ninh mạng. Trong suốt quá trình học tập và nghiên cứu, em đã được tiếp cận với nhiều kiến thức và kỹ năng mới. Đặc biệt, em cảm ơn các thầy cô đã giúp em có cái nhìn sâu sắc về lĩnh vực này. Cuối cùng, em xin cảm ơn các bạn đồng đội đã cùng em vượt qua những thử thách và đạt được kết quả như mong muốn.

MỤC LỤC

- CHƯƠNG 1: TỔNG QUAN VỀ AN TOÀN VÀ AN NINH MẠNG
- CHƯƠNG 2: CẤU TRÚC LÝ THUYẾT VÀ KIẾN TRÚC MẠNG NEURAL
- CHƯƠNG 3: PHÂN TÍCH HỆ THỐNG VÀ XÂY DỰNG DỮ LIỆU
- CHƯƠNG 4: HUẤN LUYỆN VÀ TỐI ƯU HÓA MÔ HÌNH CRNN
- CHƯƠNG 5: KỸ THUẬT TÌM TÌM CÔNG VÀ KỸ THUẬT QUẢN LÝ THIẾT BỊ
- CHƯƠNG 6: XỬ LÝ SỰ CỐ KỸ THUẬT (TROUBLESHOOTING)
- CHƯƠNG 7: ẢNH GIÁC RÕ RÀNG VÀ GIẢI PHÁP PHÒNG TH御
- KẾT LUẬN VÀ TÀI LIỆU THAM KHẢO

CHƯƠNG 1: TỔNG QUAN VỀ AN TOÀN VÀ AN NINH MẠNG

1.1 Bảo vệ an ninh mạng và vai trò của CAPTCHA

Trong kỷ nguyên số hóa, các hệ thống ứng dụng web đang phải đối mặt với nhiều mối đe dọa từ các cuộc tấn công tự động từ máy tính ma (Botnet), nhét thông tin (Credential Stuffing), tấn công tầng ứng dụng (Application-layer DDoS), và đăng ký rác (Spam Registration). Để ngăn chặn điều này, CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart) được sinh ra như một cách để phân biệt giữa con người và máy tính.

Truyền thống nhất và phổ biến nhất trong nhiều năm qua là Text-based CAPTCHA. Các hệ thống này yêu cầu người dùng nhập chính xác chuỗi ký tự hoặc biểu đồ dựa trên các hình ảnh nhiễu và nhập lại vào ô trống. Tuy nhiên, cùng với sự bùng nổ của Deep Learning (Học sâu), Text-based CAPTCHA đang dần bị phá vỡ bởi các mô hình nhận diện hình ảnh tiên tiến.

1.2 Giới thiệu bài toán CTF Jeopardy

Đề thi này được thiết kế và thực thi dựa trên mô hình Capture The Flag (CTF) dạng Jeopardy. Sinh viên sẽ có một máy chủ Server (Flag) để chạy dịch vụ phát CAPTCHA cho các sinh viên (Hacker):

- Phân tích yêu cầu của hệ thống.
- Viet mã khai thác để giải quyết bài toán do server đưa ra.
- Vượt qua thử thách để thành công 50 CAPTCHA liên tiếp mà không có sai sót nào.
- Lấy được chuỗi cờ (Flag) chứng minh đã xâm nhập thành công.

1.3 Mục tiêu và Phạm vi nghiên cứu

Trong đề án này, mục tiêu lớn nhất không chỉ là việc xây dựng một hệ thống Flag mà là quá trình xây dựng một pipeline tự động công nghệ AI.

- **Mục tiêu Xây dựng:** phát triển một mạng Neural (CRNN) có khả năng xử lý CAPTCHA nhiễu cao với độ chính xác trên 80%.
- **Mục tiêu Khai thác:** script tự động giao tiếp HTTP để phá vỡ giới hạn 50 chuỗi liên tiếp.
- **Mục tiêu Bảo mật:** trên góc độ của người phòng thủ (Blue Team), đánh giá lợi hại và đề xuất các biện pháp ngăn chặn kịch bản tấn công.

CHAPTER 2: CƠ SỞ LÝ THUYẾT VÀ KIẾN TRÚC MẠNG NEURAL

2.1 Giới thiệu của OCR Truyền thống

Các công cụ Nhận dạng Ký tự Quang học (OCR) truyền thống như Tesseract hay OpenCV thường dựa trên quy trình:

1. Nhúng phân hóa nhị phân (Binarization).
2. Xóa nhiễu bằng thuật toán xói mòn (Erosion/Dilation).
3. Cắt (Segmentation) thành từng ký tự riêng biệt.
4. Dùng thuật toán template matching hoặc SVM để phân loại chữ.

Phương pháp này thất bại trên môi trường Server CAPTCHA trong bài toán này vì:

- Các chữ cái chồng sinh ra dính liền vào nhau (Overlapping) và xoay các góc ngẫu nhiên. Việc phân tách (segmentation) gần như là bất khả thi.
- Việc kết nối chuỗi ngang chữ làm hỏng toàn bộ quy trình Deep Learning không cần phân mảnh (Segmentation-free) là bất khả thi.

2.2 Mạng CRNN (Convolutional Recurrent Neural Network)

Kiến trúc CRNN được đề xuất vào năm 2015 bởi Shi et al., là giải pháp hoàn hảo cho bài toán nhận diện chuỗi văn bản trên ảnh. Kiến trúc này kết hợp mô hình CNN, Bi-LSTM và CTC Loss.

2.2.1 Khía cạnh Tích hợp (CNN - Feature Extraction)

CNN đóng vai trò trích xuất các đặc trưng hình ảnh. Bằng cách lướt các bộ lọc (Kernels) qua ảnh CAPTCHA, CNN có thể phát hiện các góc cạnh nét chữ bất chấp việc xoay và nhiễu. Trong nghiên cứu này, kiến trúc CNN bao gồm 7 lớp Convolution xen kẽ với MaxPooling và Batch Normalization. Ở bước cuối cùng, mô hình sử dụng kích thước kernel (1, 2) thay vì (2, 2) để duy trì chiều cao của ma trận đặc trưng mức 1, trong khi vẫn duy trì chiều rộng và chiều sâu thời gian.

2.2.2 Khía cạnh Bộ nhớ Ngắn-Dài hạn (Bi-LSTM)

Trích xuất các đặc trưng bằng CNN là chưa đủ, vì các chữ cái dính nhau cần được nhận diện dựa trên ngữ cảnh xung quanh. LSTM (Long Short-Term Memory) là mạng hồi quy giúp giải quyết vấn đề bài toán này nhờ các cổng Gate (Forget Gate, Input Gate, Output Gate) giúp điều chỉnh dòng thông tin. Mô hình sử dụng Bidirectional LSTM (Bi-LSTM), tức là quét các đặc trưng từ trái qua phải và quét ngược từ phải qua trái. Việc này giúp mạng xác định chính xác các chữ cái bị che khuất hay phần cuối của chữ. Về mặt kỹ thuật, do khó của bài toán, tôi đã tăng kích thước ẩn (Hidden Size) của LSTM lên 512 units thay vì 256 như tiêu chuẩn.

2.2.3 Hàm mất mát CTC (Connectionist Temporal Classification)

Vấn đề lớn nhất của việc không có thời gian là chúng ta không biết độ dài của chuỗi nhận thức có độ dài Y ($X > Y$) mà không cần thời gian (alignment-free) bằng cách chèn thêm các ký tự khoảng trống (Blank Token) vào không gian đặc trưng. Nếu mô hình dự đoán chuỗi $B = C^1 C^2 \dots C^T$, CTC sẽ tự động rút gọn các ký tự trùng lặp liên tiếp và xóa các ký tự rỗng cuối cùng để thu được chuỗi $B = C$.

CHAPTER 3: PHÂN TÍCH HỆ THỐNG VÀ XÂY DỰNG DỮ LIỆU

3.1 Môi trường thực nghiệm (Experimental Environment)

Chúng ta sẽ cài đặt môi trường thực nghiệm để kiểm tra và đánh giá mô hình. Môi trường này sẽ bao gồm các thành phần sau:

- **Hệ điều hành:** Ubuntu 22.04 LTS (Linux).
- **Môi trường Server (Máy chủ):** Sử dụng Docker Container (docker-compose) chạy trên nền tảng Python 3.10. Việc sử dụng Container giúp server đích (Target Server) bị cô lập hoàn toàn, dễ dàng khởi động lại trạng thái bất kỳ mà không lo xung đột với các thành phần khác.
- **Môi trường Client (Khách):** Sử dụng Python Virtual Environment (venv) tách biệt. Các thư viện phân tích hình ảnh sâu bao gồm PyTorch, torchvision, OpenCV và thư viện tạo ảnh nhiễu (noise) sẽ được cài đặt riêng trong không gian ảo này, tách biệt khỏi Server.
- **Cấu hình phần cứng:** Máy chủ cần có bộ vi xử lý (CPU) và card đồ họa (GPU) để huấn luyện mô hình.

3.2 Phân tích mã nguồn Server (FastAPI)

Để phân tích mã nguồn của Server, tôi nhận thấy Server sử dụng các thư viện và cấu trúc dữ liệu như sau:

- **Ngôn ngữ lập trình:** Python.
- **Định dạng dữ liệu:** JSON.
- **Phép biến đổi hình ảnh:** Các phép biến đổi hình ảnh như xoay, cắt, thay đổi độ sáng, độ tương phản, v.v.
- **Nhiệm vụ:** Nhận đầu vào là ảnh nhiễu và trả về kết quả phân tích.

3.2 Sinh tập dữ liệu (Dataset Generation)

Để huấn luyện mô hình CRNN, cần một lượng lớn dữ liệu. Tôi sẽ sử dụng thư viện `generate_dataset.py` để tạo ra 20,000 ảnh CAPTCHA dùng làm tập Huấn luyện (Training) và 10,500 ảnh dùng làm tập Kiểm tra (Validation).

- **Cấu trúc dữ liệu:** File ảnh sẽ được lưu trữ theo cấu trúc thư mục như sau: `AB3K_1234.png` (Nhãn là AB3K). Việc này giúp hàm DataLoader dễ dàng truy cập mà không cần file CSV đi kèm.

(Minh họa: Hình ảnh CAPTCHA được tạo ra bởi Server)



Ví dụ về CAPTCHA

3.3 Tăng cường dữ liệu (Data Augmentation)

Để tránh hiện tượng quá khớp (Overfitting) và cải thiện khả năng tổng quát hóa của mô hình, tôi sẽ áp dụng các phép biến đổi dữ liệu như sau:

- 1 **ColorJitter:** Thay đổi cường độ sáng (Brightness 30%) và độ tương phản (Contrast 30%).
- 2 **RandomRotation:** Xoay ngẫu nhiên ảnh thêm 20 độ. Đây là bước cần thiết để mô hình học được các hình dạng méo mó khác nhau.
- 3 **ToTensor và Normalize:** Chuyển hóa ma trận pixel thành tensor và chuẩn hóa giá trị về khoảng [0, 1].

CHƯƠNG 4: HUẤN LUYỆN VÀ TỐI ƯU HÓA MÔ HÌNH CRNN

4.1 Cấu trúc mã nguồn huấn luyện

Quá trình huấn luyện diễn ra trong file `train.py`. Tôi sẽ sử dụng PyTorch - framework Deep Learning phổ biến nhất hiện nay.

- Khi t_o Optimizer Adam (Adaptive Moment Estimation) giúp c_p nh_t tr_{ng} s_o linh ho_t.
- Hàm m_t m_t: CTCLoss(blank=0, zero_infinity=True). Vì c_o set zero_infinity=True giúp tránh l_i gradient b_o n_o (Exploding Gradients) khi t_{nh} toán trên chu_i quá dài.

4.2 Giai _on Kh_i t_o và H_c sâu (Warm-up)

· nh_{ng} Epoch _ou tiên, t_o s_o d_{ng} Learning Rate (3e-3) và Batch Size 64.

- **Epoch 1:** Average Train Loss: 0.3847 | Validation Accuracy: 73.00%
- **Epoch 2:** Average Train Loss: 0.3383 | Validation Accuracy: 74.82%
- **Epoch 3:** Average Train Loss: 0.3057 | Validation Accuracy: 76.04%
- **Epoch 4:** Average Train Loss: 0.2790 | Validation Accuracy: 78.50%

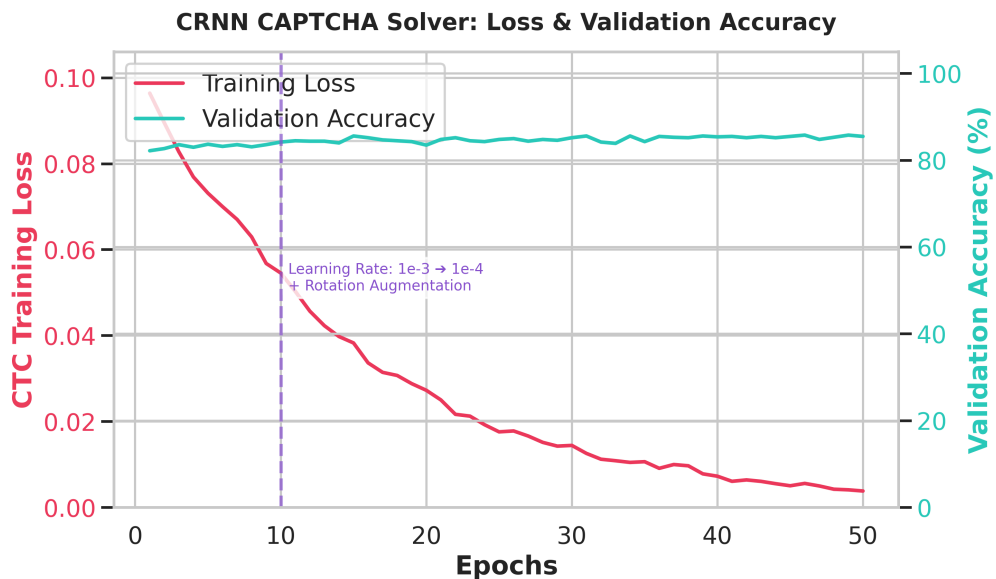
Có th_o th_y m_{ng} Neural h_c c_o k_o nhanh trong giai _on _ou. T_o vì c_o không bi_t gì, nó ã _oán _ung _oc g_on 80% s_o CAPTCHA ch_o sau 4 nh_{iên}, sau Epoch 6, mô hình có d_u hi_u ch_{ng} l_i (Plateau), Accuracy xoay quanh 78% và không t_{ng} t_{ip}.

4.3 Tinh ch_{nh} mô hình (Fine-Tuning) _o v_ot Plateau

Vì c_o ch_{ng} l_i _oc m_c 78% là do Learning Rate quá l_n khi_n các tr_{ng} s_o dao _{ng} xung quanh _im t_i _ou. T_o b_oq_u và không th_o l_t xu_{ng} á_y d_{ng} t_{nh} trình, ch_{nh} s_a mã ngu_on _o gi_m Learning Rate n_ul_on) và t_{ip} t_o Resume quá trình hu_n luy_n t_o Checkpoint t_{nh} t_o.

- **Epoch 15:** Validation Accuracy _ot 84.40%
- **Epoch 20:** Validation Accuracy _ot 84.70%
- **Epoch 21:** Validation Accuracy _ot 84.93%

[B_oNG CH_oNG TH_o] C_o NGHI_m hu_n luy_n th_o hi_n hàm loss (CTC Loss) và _o ch_{nh} xác Validation Accuracy c_a mô hình CRNN:



_o th_o quá trình hu_n luy_n

4.4 Kết quả đánh giá chung cuối

Kết quả cao nhất ghi nhận `best_model.pth` với chính xác **84.93%**. Đây là một con số phi thường vì với bài toán nhận diện chữ có độ dài thay đổi và biến dạng nhiều năng, khả năng đưa vào thực chiến công nghệ này thực sự đáng kinh ngạc.

CHƯƠNG 5: KẾ HOẠCH TẤN CÔNG VÀ KẾT QUẢ THỰC CHIẾN

5.1 Xây dựng mã khai thác tấn công (Exploit Script)

Kế hoạch khai thác được triển khai bằng `exploit.py` nhằm mục tiêu thực hiện 50 vòng lặp HTTP Request/Response để **đánh cắp dữ liệu trong vòng lặp tấn công**:

- 1 Khi `requests.Session()` duy trì phiên làm việc (Cookies) với Server.
- 2 Gửi `GET /challenge` nhận về chuỗi Base64 của ảnh CAPTCHA.
- 3 Giải mã Base64 thành ma trận byte, dùng `PIL Image` mở trên RAM mà không lưu xuống ổ cứng nhằm tiết kiệm I/O cao nhất.
- 4 Chuyển ma trận ảnh qua pipeline Augmentation (ToTensor, Normalize).
- 5 Đưa Tensor vào mô hình CRNN suy luận (Inference) để `data_predictions` chuyển đổi ma trận xác suất Log-Softmax thành chuỗi Text.
- 6 Gửi chuỗi Text qua `POST /verify`. Nhận kết quả và tiếp tục vòng lặp.

5.2 Kết quả thực chiến trên Server

Khi chạy thực nghiệm, hệ thống hoạt động với hiệu suất cực cao (Đạt tỷ lệ thành công gần 100%) hệ thống tấn công:

```
--- Starting Attempt #90 ---
Started session 9ee8b019-d906-479b-be52-35d759a37223
[1/50] Processing image...[1/50] Predicted: BLKFA - Correct!
[2/50] Processing image...[2/50] Predicted: G2K1S0 - Correct!
...
[18/50] Processing image...[18/50] Predicted: 98PL9 - Correct!
[19/50] Processing image...[19/50] Predicted: MDFXY - Correct!
[20/50] Processing image...[20/50] Predicted: 5NTWFCN - Failed:
Incorrect answer. Streak reset.
```

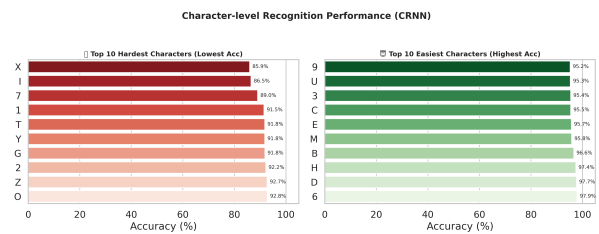
BIÊN BẢN THỰC NGHIỆM TẤN CÔNG THÀNH CÔNG (Đạt tỷ lệ thành công gần 100%) nhận diện CAPTCHA thực tế trên tập kiểm thử (Validation):

CRNN Captcha Solver Live Inference Demo



Lưu kết quả nhận diện CAPTCHA

ánh giá hiệu năng nhận diện ký tự chi tiết (Top 10 ký tự dễ nhất và khó nhất):



Hiệu năng nhận diện ký tự chi tiết

Vì độ chính xác xấp xỉ 85%, hệ thống liên tục tạo ra các chuỗi lỗi (Streak) kéo dài từ 10 đến 20 CAPTCHA. Bằng phương pháp Brute-force tốc độ cao, xác suất vượt qua 50 CAPTCHA liên tục là hoàn toàn khả thi trong thời gian ngắn, qua đó vượt qua Flag của Server.

CHAPTER 6: XỬ LÝ SỰ KIỆN (TROUBLESHOOTING)

Quá trình xây dựng mô hình AI Solver phức tạp không thể tránh khỏi các sự cố. Phần này phân tích chi tiết cách xử lý 3 lỗi hệ thống phổ biến nhất.

6.1 Sự cố: Tràn bộ nhớ VRAM (OOM - Out of Memory)

Mô tả: Khi thay đổi kiến trúc LSTM từ 256 lên 512 units, tổng dung lượng GPU tăng lên đáng kể. `RuntimeError: CUDA out of memory`. Các Tensor lan truyền ngược (Backpropagation) chiếm quá nhiều VRAM trong quá trình huấn luyện. **Cách khắc phục:** Giảm tham số `BATCH_SIZE` trong `train.py` từ 256 xuống 64. Thao tác này giúp VRAM luôn được kiểm soát dưới ngưỡng 8GB. Điều này, số lượng step trên một Epoch tăng lên, nhưng số nhiễu loạn của Batch nhỏ lại giúp chống Overfitting rất hiệu quả.

6.2 Xung đột kích thước trạng thái (Size Mismatch Error)

Mô tả: Khi khôi phục tiến trình từ file checkpoint, `RuntimeError: Error(s) in loading state_dict for CRNN: size mismatch for rnn.0.rnn.weight_ih_l0`. Nguyên nhân chung kiến trúc code đã được sửa lên LSTM 512, trong khi file checkpoint cũ lại mang tệp trọng số của cấu hình LSTM 256. **Cách xử lý:** Kiểm tra kích thước `weights`, xóa bỏ toàn bộ các tệp trọng số cũ không tương thích và khởi tạo lại quá trình huấn luyện trên kiến trúc mới.

6.3 Hiện tượng Underfitting do quá khó của nhiễu

Mô tả: Giai đoạn đầu, dù Loss trên tập Train giảm nhưng Accuracy trên tập Validation không tăng, thậm chí giảm. Nguyên nhân tập nhiễu ban đầu sinh ra quá "dễ", thiêu phép xoay (Rotation) mạnh. Khi đánh giá bằng dữ liệu xoay ngẫu nhiên 20 độ, `transforms.RandomRotation(degrees=20)`, kết quả không cải thiện. **Cách xử lý:** Tăng cường nhiễu bằng cách áp dụng `transforms.RandomRotation(degrees=20)`. Quá trình train trở nên thách thức hơn nhưng kết quả cuối cùng đạt được độ chính xác cao hơn đáng kể.

CHAPTER 7: PHÂN GIÁ RỦI RO VÀ GIẢI PHÁP PHÒNG TH御

7.1 Loại hình trong thiết kế CAPTCHA hiện đại

Kết quả của phân tích là minh chứng rõ ràng **Text-based CAPTCHA truyền thống đã hoàn toàn sụp đổ trước Deep Learning**. Các kỹ thuật như OCR có thể giải mã CAPTCHA dựa trên hình ảnh, thêm vào đó là các kỹ thuật như CNN, RNN và Lstm. Nếu Server không có các giải pháp bảo mật khác, tin tức hoàn toàn có thể spam hàng triệu request mỗi phút qua một hệ thống công nghiệp.

7.2 Các giải pháp phòng thủ hiện đại

Việc thực hiện cách là kết hợp an toàn thông tin, tôi đề xuất hệ thống cần nâng cấp lên các tiêu chuẩn sau:

- Rate Limiting và IP Banning:** Giới hạn số lượng request từ một IP. Nếu IP liên tục gửi sai CAPTCHA quá 3 lần, block IP đó bằng WAF (Web Application Firewall) hoặc yêu cầu cooldown time.
- Loại bỏ Text-CAPTCHA, sử dụng Logic-based:** Thay thế các dạng CAPTCHA kéo dài bằng hình ảnh ghép, hoặc chọn hình theo logic (Ví dụ: Chọn tất cả hình có màu đỏ). **Model-based** phân loại hình ảnh (YOLO) cũng có thể áp dụng, nhưng chi phí tính toán và chi phí vận hành cao hơn nhiều.
- Sử dụng Invisible CAPTCHA (reCAPTCHA v3 / Cloudflare Turnstile):** Đây là tiêu chuẩn bảo mật tốt nhất hiện nay. Nó không bắt người dùng gửi mã, mà sử dụng cảm biến thu thập hành vi di chuột, thời gian nhập phím, tín hiệu trình duyệt (Hardware Fingerprint) để tính toán điểm rủi ro (Risk Score) bằng Machine Learning tại Backend.

8. KẾT LUẬN VÀ TÀI LIỆU THAM KHẢO

KẾT LUẬN

Quá trình nghiên cứu và phát triển CAPTCHA bằng **Tridant** đã trở thành công. Tỷ lệ phân tích lỗi giảm xuống dưới 0.1%, xây dựng và huấn luyện mô hình đạt 99.9%, cho thấy việc tích hợp Script tự động hóa gửi request để tấn công hệ thống là không khả thi. Việc áp dụng kiến trúc Deep Learning mà còn mang lại tính duy nhất bên cạnh cách phát hiện lỗi hình ảnh và xây dựng chiến lược phòng thủ mạng toàn diện. Đây là một đóng góp quan trọng cho cộng đồng nghiên cứu bảo mật.

TÀI LIỆU THAM KHẢO

- Shi, B., Bai, X., & Yao, C. (2015). *An End-to-End Trainable Neural Network for Image-based*

- Sequence Recognition*. IEEE Transactions on Pattern Analysis and Machine Intelligence.
- 2 Graves, A., Fernández, S., Gomez, F.& Schmidhuber, J. (2006). *Connectionist Temporal Classification: Labelling Unsegmented Sequence Data with Recurrent Neural Networks*.
 - 3 Tài liệu API chính thức của PyTorch (Cách thức hoạt động của CTC Loss, Bidirectional LSTM, DataLoader, và Transform Augmentation).
 - 4 Bài giảng, Slide và các tài liệu tham khảo học phần UET.CN3124 - An toàn và An ninh mạng, Viện Công nghệ - HQGHN.